SHAREPOINT PRODUCTION PROTECT — NOT VERIFIED

Date: 2026-11-03 · **Branch:** `claude/modest-bell-tazupa` · **Code commit tested:** `654db0e` (HEAD `7e8cb39` adds docs only)

The verdict is **NOT VERIFIED**. This is the correct outcome, not a failure of the engineering work. Production protection may be declared only from end-to-end evidence on the real tenant: real Entra employees, a real SharePoint permission change, live Guard and Gateway traffic, and an independently signed certificate, followed by human reviewer approval. None of those can be produced from this environment, and none has been fabricated.

1. What is done and verified

Area	Status	Evidence
P0-01 superuser bypassed RLS	FIXED, verified locally and on the rehearsal stand-in	3 roles, all `NOSUPERUSER NOBYPASSRLS`, owning nothing. FORCE RLS on 58/58 tenant tables. The running API, measured live, is `accessproof_app` (`docs/evidence/rehearsal-2026-11-03/db-runtime-audit.json`).
Full test suite, SQLite	1355 passed, 0 failed, 10 skipped (1365 tests)	`ACCESSPROOF_TEST_RESULTS.json`
Full test suite, PostgreSQL 17 with API as restricted `accessproof_app`	1361 passed, 0 failed, 4 skipped (1365 tests)	`ACCESSPROOF_TEST_RESULTS.json`
Sanitizer bypass (entity-encoded URLs in CSS and event handlers)	FIXED (v2); verified in real Chromium	`test_output_exfiltration_real_renderer.py`
Participant-aware authorization	Trusted Ed25519 roster from an authenticated adapter; `single_user` by default	`test_participant_aware_authorization.py`
Independent certifier	Ed25519; API holds public keys only; signer material in API env fails closed	`test_source_certificate_trust_boundary.py`
Gateway liveness	Authenticated heartbeat. Installation history is never treated as connectivity.	`test_gateway_presence.py`
Guard readiness	Computed, never hardcoded; production refuses static identity	D-03
Production gates A–J	Implemented; PASS only on genuine evidence; tamper/skip → FAIL/BLOCKED	`test_production_gates.py`

Area	Status	Evidence
Release rehearsal	deploy → least-privilege switch → probe 20/20 → gates → 2nd release → forced failure → rollback	`docs/evidence/rehearsal-2026-11-03/`

The rehearsal found **five real release defects (D-09 … D-13)**. All are now fixed. Two would have caused production outages:

- **D-12:** after the switch, every later migration would have run as a role with no DDL rights.
- **D-13:** re-running the switch rotated passwords. A later failure then restored a `.env` that no longer matched the database, locking the API out while the script reported success.

See `docs/ACCESSPROOF_DEFECT_REGISTER.md`.

2. Gate status (measured live on the rehearsal stand-in, r23, as `accessproof_app`)

Gate	Status	Why
A Infrastructure	**PASS**	api/worker/db/redis/web healthy; migration at head; rollback state present
B Identity	FAIL	0 verified Entra employee mappings. Requires real Alice/Bob sign-in.
C SharePoint source	FAIL	No sync against a real tenant; no independently issued certificate
D Guard	FAIL	No enrolled live Guard on the stand-in
E Gateway	FAIL	No heartbeat-capable Gateway; no route certificate
F Layer 1	FAIL	No real retrieval traffic observed
G Layer 2	FAIL	No verified release observed; in-flight/tamper evidence requires a certificate
H Revocation & cache	BLOCKED	Requires provider-observed revoke/restore carried in certified evidence
I Database security	**PASS**	Runtime role non-superuser, NOBYPASSRLS, owns nothing; 58 tables policied; no settable bypass; metrics role configured
J Activation	FAIL	Backend checklist (same code that gates Protect) has unmet items

Raw output: `docs/evidence/rehearsal-2026-11-03/gates-r23-least-privilege.json`.

3. Exact blockers (none can be resolved from this environment)

1. **Production access.** AWS STS rejects the available credentials (`InvalidClientTokenId`). `api.accessproof.in`, `app.accessproof.in` and `graph.microsoft.com` are denied by this session's network policy, and no Remote Control computer is attached.
2. **Database role change approval.** `enable_least_privilege_db.sh` is a privileged production change and requires the owner's explicit `--approve-database-role-change`.
3. **Certifier key.** It must be generated **off the API host** by the owner.
4. **Real Entra employees.** Alice and Bob must sign in interactively. No Microsoft identity is fabricated.
5. **Authorized revoke/restore trial.** It must run on the synthetic SharePoint site with owner approval, to measure revocation propagation and cache invalidation.

6. **Reviewer approval.** A human decision recorded outside the code, even once every technical gate passes.

4. Operator runbook (in order)

All commands run from a machine with production AWS credentials, on the repository at commit `7e8cb39eace4` or later.

```
bash deploy/ec2-release/ship_via_ssm.sh            # builds, deploys, verifies; auto-rollback on failure
```

Then on the host (via SSM), with explicit owner approval:

```
sudo bash /home/ubuntu/accessproof-releases/<release>/enable_least_privilege_db.sh <release> --approve-database-role-change
```

Off-host, by the owner:

```
python scripts/issue_source_certificate.py keygen --private-key certifier.key   # 0600; prints public-key JSON. Keep the key offline.
```

Then:

1. Set `ACCESSPROOF_SOURCE_CERTIFICATION_PUBLIC_KEYS_JSON` and recreate the api.
2. Alice and Bob sign in with Entra. Run the authorized revoke/restore trial and the protected-route tests, and collect the 14 `REQUIRED_CHECKS` as evidence.
3. Issue and import the certificate (`issue_source_certificate.py issue` / `import`).
4. Run the gates:

   ```
   sudo bash /home/ubuntu/accessproof-releases/<release>/run_security_gates.sh <org-id> <application-id> evidence.json
   ```

5. If the verdict is `TECHNICAL_GATES_PASSED_PENDING_REVIEWER_APPROVAL`, the reviewer records approval.

Rollback. Run `rollback_on_ec2.sh <release>`. It migrates as the owner and warns if the rollback crosses the least-privilege switch. If a switch failure leaves the API down, re-run the switch with `RECOVERY=1`.

5. Security rules honoured

- No authorization was bypassed.
- No identity, certificate or evidence was fabricated.
- Guard readiness and source ACL health are computed, never set.
- Layer 1, Layer 2, provenance and tenant isolation were never disabled.
- No production secret appears in the repository.
- The rehearsal artifacts were scanned for the generated passwords and tokens before commit.
- Nothing was deployed to production, and no production data was touched.
- No PR was created.